

## **48. SEGURIDAD DE SISTEMAS (2). EL ESQUEMA NACIONAL DE SEGURIDAD. ADECUACIÓN AL ESQUEMA NACIONAL DE SEGURIDAD. ESTRATEGIA NACIONAL DE SEGURIDAD. CCN-STIC.**

Actualizado a 05/03/2026

## Contenido

|     |                                                                  |    |
|-----|------------------------------------------------------------------|----|
| 1   | Esquema Nacional de Seguridad (ENS) – RD 311/2022                | 3  |
| 1.1 | Ideas principales                                                | 3  |
| 1.2 | Guías de seguridad CCN-STIC                                      | 5  |
| 2   | Adecuación de sistemas al ENS                                    | 6  |
| 3   | Categorización del sistema de acuerdo al ENS                     | 6  |
| 4   | Medidas de seguridad                                             | 8  |
| 4.1 | Marco organizativo                                               | 8  |
| 4.2 | Marco operacional                                                | 8  |
| 4.3 | Medidas de protección                                            | 10 |
| 5   | Instrucciones Técnicas de Seguridad (ITS)                        | 12 |
| 5.1 | ITS de informe del estado de la seguridad                        | 12 |
| 5.2 | ITS de conformidad con el ENS                                    | 13 |
| 5.3 | ITS de notificación de incidentes de seguridad                   | 13 |
| 5.4 | ITS de auditoría de seguridad de sistemas de información         | 14 |
| 6   | Directiva NIS2, un alto nivel de seguridad común en la UE        | 14 |
| 7   | Otra normativa europea aplicable a la seguridad                  | 15 |
| 8   | Estrategia de Seguridad Nacional                                 | 16 |
| 8.1 | Seguridad global y vectores de transformación (Cap. 1)           | 16 |
| 8.2 | Una España segura y resiliente (Cap. 2)                          | 17 |
| 8.3 | Riesgos y amenazas a la seguridad nacional (Cap. 3)              | 17 |
| 8.4 | Un planteamiento estratégico integrado (Cap. 4)                  | 17 |
| 8.5 | El Sistema de Seguridad Nacional y la Gestión de Crisis (Cap. 5) | 17 |

## 1 ESQUEMA NACIONAL DE SEGURIDAD (ENS) – RD 311/2022

### 1.1 IDEAS PRINCIPALES

En la sección III del preámbulo del RD se establecen los tres objetivos del ENS:

1. Alinear el ENS con el marco normativo y el contexto estratégico existente para garantizar la seguridad en la administración digital.
2. Introducir el concepto “perfil de cumplimiento específico” para garantizar la adaptación del ENS a la realidad de ciertos colectivos o tipos de sistemas, buscando una adaptación del ENS más eficaz y eficiente, racionalizando los recursos requeridos sin menoscabo de la protección perseguida y exigible.
3. Mejorar la capacidad de respuesta ante incidentes, reducir vulnerabilidades y promover la vigilancia continua, de forma completamente alineada con la Directiva NIS2. Además, permitir aplicar sanciones indirectas al ENS.

El nuevo ENS se encuadra dentro del componente 11 del Plan Nacional de Recuperación, Transformación y Resiliencia y de la Agenda España Digital 2026, viéndose complementado con el Centro de Operaciones de Ciberseguridad de la AGE (COCS) (<https://www.ccn.cni.es/index.php/en/docman/documentos-publicos/486-ccn-aproximacion-soc-nacionales/file>).

Los sistemas que se ven afectados por el ENS, es decir, el **ámbito subjetivo** del ENS es:

- El definido en el artículo 2 de la Ley 40/2015:
  - La Administración General del Estado.
  - Las Administraciones de las Comunidades Autónomas.
  - Las Entidades que integran la Administración Local.
  - El sector público institucional:
    - Organismos públicos y entidades de derecho público vinculados o dependientes de las AAPP.
    - Entidades de derecho privado vinculadas o dependientes de las AAPP cuando ejerzan potestades administrativas.
    - Las Universidades públicas, que se regirán por su normativa específica y, supletoriamente, por las previsiones de Ley 40/2015.
- Sistemas que tratan información clasificada, aplicándoles aquellas medidas adicionales exigidas por compromisos internacionales.
- Sistemas de información de las entidades del sector privado, cuando de acuerdo con la normativa aplicable y en virtud de una relación contractual presten servicios a las entidades del sector público para el ejercicio por éstas de sus competencias y potestades administrativas.

De acuerdo a la Ley 40/2015, las AAPP podrán determinar sistemas a los que NO es de aplicación el ENS si estos:

- No están relacionados con el ejercicio de derechos ni con el cumplimiento de deberes por medios electrónicos.
- No están relacionados con el acceso por medios electrónicos de los ciudadanos a la información y al procedimiento administrativo.

Las dimensiones de seguridad definidas en el ENS son ACIDT (Anexo I): Autenticidad, Confidencialidad, Integridad, Disponibilidad y Trazabilidad.

Cada administración pública contará con una política de seguridad formalmente aprobada por el órgano competente. En el caso de la AGE, cada ministerio contará con su política de seguridad. La política de seguridad se establecerá de acuerdo con los principios básicos definiendo directrices para la

estructuración de los documentos de seguridad, su gestión y acceso y se desarrollará aplicando los siguientes requisitos mínimos, en proporción a los riesgos identificados en cada sistema.

Principios básicos (capítulo II, artículo 5 del ENS):

- a) Seguridad como proceso integral.
- b) Gestión de la seguridad basada en los riesgos.
- c) Prevención, detección, respuesta y conservación.
- d) Existencia de líneas de defensa.
- e) Vigilancia continua (nuevo con respecto al RD 3/2010).
- f) Reevaluación periódica.
- g) Diferenciación de responsabilidades.

Requisitos mínimos (capítulo III, artículo 12 del ENS):

- a) Organización e implantación del proceso de seguridad (se mantienen los 4 responsables: de información, de servicio, de seguridad y de sistema).
- b) Análisis y gestión de los riesgos (ver herramienta PILAR del CCN-CERT).
- c) Gestión de personal.
- d) Profesionalidad.
- e) Autorización y control de los accesos.
- f) Protección de las instalaciones.
- g) Adquisición de productos de seguridad y contratación de servicios de seguridad (aquellos servicios que se contraten a terceros han de asegurar la conformidad con el ENS; esto es nuevo con respecto al RD 3/2010).
- h) Mínimo privilegio.
- i) Integridad y actualización del sistema.
- j) Protección de la información almacenada y en tránsito (ver herramienta CARLA).
- k) Prevención ante otros sistemas de información interconectados (ver herramienta REYES).
- l) Registro de la actividad (ver herramientas MONICA y GLORIA) y detección de código dañino (ver herramientas ADA, MARTA y MARIA) (la detección es nueva con respecto al RD 3/2010).
- m) Incidentes de seguridad (ver herramienta LUCIA). Definir criterios de clasificación, procedimientos, cauces de comunicación y registro de actuación.
- n) Continuidad de la actividad.
- o) Mejora continua del proceso de seguridad (ver herramienta IRIS).

El RD proporciona cierta flexibilidad de cara a que el ámbito subjetivo se adapte eficaz y eficientemente al ENS. El artículo 28 y el último apartado del artículo 12 dejan la puerta abierta a la exigencia de los requisitos mínimos en proporción a los riesgos identificados en cada sistema. También se da la posibilidad de modificar las medidas de seguridad a aplicar (Anexo II) relacionadas. Además, prevalecerán las medidas del análisis y gestión de riesgos (AGR) y, en su caso, de la evaluación de impacto de protección de datos (EIPD), en caso de que resulten agravadas. Se remarca la asignación de responsabilidades y el establecimiento de mecanismos de resolución de conflictos.

Las medidas de seguridad se encuentran descritas en el Anexo II. Se aplican a los marcos organizativo y operacional, así como a las medidas de protección. La relación de las medidas aplicadas en el organismo formará parte del documento “Declaración de Aplicabilidad” (artículo 28).

En línea con el segundo de los objetivos del ENS definidos en el preámbulo, se permite la implementación de perfiles de cumplimiento del ENS específicos para determinadas entidades o sectores de actividad concretos. Hay que recordar que, según el ámbito subjetivo, el ENS se ha de aplicar más allá de las fronteras de la AGE.

De la misma manera, para poder implementar determinadas soluciones tecnológicas o plataformas suministradas por terceros, se podrán implementar esquemas de acreditación de entidades y validación

de personas, que garanticen la seguridad de estas soluciones/plataformas. Los servicios externalizados deberán proporcionar un punto o persona de contacto (POC).

Los profesionales tendrán que tener en cuenta la seguridad durante todo el ciclo de vida del sistema de información hasta su desmantelamiento.

Para poder aplicar estos perfiles de cumplimiento específicos y los esquemas de acreditación, el CCN ha de validarlos de acuerdo a las Instrucciones Técnicas de Seguridad (ITS) y las guías del *Computer Emergency Response Team* del CCN o CCN-CERT (artículo 30).

Auditoría de seguridad (Cap. IV artículo 31 y Anexo III): Mínimo cada 2 años (auditoría ordinaria), y además siempre que se produzcan modificaciones sustanciales en el sistema que puedan repercutir en la seguridad (auditoría extraordinaria). Los sistemas de categoría BÁSICA no necesitan realizar auditoría de seguridad, basta con que realicen una autoevaluación. Los resultados de la auditoría de seguridad serán presentados al responsable del sistema y al responsable de seguridad. El responsable de seguridad analizará la auditoría y pedirá al responsable del sistema que adopte las medidas adecuadas. El plazo mínimo de 2 años puede ampliarse a 3 meses más por impedimentos de fuerza mayor.

Informe de estado de seguridad de los sistemas (Cap. IV artículo 32): El CCN establecerá los procedimientos y herramientas para recopilar la información sobre el estado de seguridad de los sistemas de las distintas AAPP. La Comisión Sectorial de Administración Electrónica (CSAE) elaborará con dicha información un perfil general del estado de la seguridad en las entidades titulares de los sistemas de información comprendidos en el ámbito de aplicación del artículo 2. Se desarrolla en una ITS.

Respuesta a incidentes de seguridad (Cap. IV artículo 33): Las AAPP deberán notificar los incidentes al CCN-CERT. En el caso de un operador con incidencia en la Defensa Nacional, se avisará al ESPDEF-CERT. Las organizaciones del sector privado que prestan servicio a entidades públicas avisarán al INCIBE-CERT.

CCN-CERT. Prestación de servicios (Cap. IV artículo 33): El CCN-CERT, en relación a la respuesta a incidentes de seguridad a las entidades del sector público, prestará a las AAPP servicios de soporte y resolución de incidentes de seguridad, elaborará las guías CCN-STIC, ofrecerá formación en seguridad informática, recomendaciones, herramientas, etc.

Normas de conformidad (Cap. V artículo 38): Los órganos y Entidades de Derecho Público darán publicidad en las correspondientes sedes electrónicas de las declaraciones de conformidad y distintivos de seguridad que tengan. Es desarrollado en una ITS.

Los sistemas de categoría MEDIA o ALTA precisarán de una auditoría de certificación de conformidad de ENS (además de la auditoría de seguridad nombrada anteriormente). Los sistemas de categoría BÁSICA sólo requerirán una autoevaluación para su declaración de conformidad.

Categorización de los sistemas (Cap. VII artículo 40 y Anexo I): Los sistemas se categorizan como BAJO/MEDIO/ALTO en cada una de las dimensiones ACIDT en función del impacto que tendría un incidente de seguridad sobre la capacidad de la organización y sus activos.

## **1.2 GUÍAS DE SEGURIDAD CCN-STIC**

Las guías CCN-STIC son normas, instrucciones, guías y recomendaciones elaboradas para el mejor cumplimiento de lo establecido en el ENS. Se organizan en series, siendo la serie 800 relativa al ENS. Son especialmente relevantes:

- ✓ CCN-STIC-801. Responsabilidades y Funciones en el ENS – Define los diferentes roles.
- ✓ CCN-STIC-802. Auditoría del ENS.
- ✓ CCN-STIC-803. Valoración de Sistemas en el ENS – Desarrolla cómo realizar la categorización.
- ✓ CCN-STIC-804. ENS. Guía de implantación.
- ✓ CCN-STIC-805. Esquema Nacional de Seguridad. Política de seguridad de la información.
- ✓ CCN-STIC-806. Plan de Adecuación al ENS.

- ✓ CCN-STIC-807 Criptología de empleo en el ENS.
- ✓ CCN-STIC-808. Verificación de Cumplimiento del ENS – Publicada en noviembre de 2022.
- ✓ CCN-STIC-809. Declaración, certificación y aprobación provisional de conformidad con el ENS y distintivos de cumplimiento.
- ✓ CCN-STIC-811 Interconexión en el ENS.
- ✓ CCN-STIC-812 Seguridad en Entornos y Aplicaciones web.
- ✓ CCN-STIC-817 Gestión de Ciberincidentes.
- ✓ CCN-STIC-825 Esquema Nacional de Seguridad. Certificaciones 27001.
- ✓ CCN-STIC-831. Registro de la actividad de los usuarios.

Algunas clasificaciones según conceptos generales que pueden ser de utilidad:

Redes inalámbricas:

- ✓ CCN-STIC-816 Seguridad en Redes Inalámbricas en el ENS.
- ✓ CCN-STIC-837. ENS. Seguridad en Bluetooth.

Relacionado con seguridad en los endpoints:

- ✓ CCN-STIC-836 Seguridad en VPN en el marco del ENS.
- ✓ CCN-STIC-827 Gestión y uso de dispositivos móviles.
- ✓ CCN-STIC-834. Protección ante Código Dañino en el ENS.

En la nube:

- ✓ CCN-STIC-823. Utilización de servicios en la nube.
- ✓ Familia CCN-STIC-884 Seguridad en Azure (Ej: CCN-STIC-884D Guía de configuración segura para servicios de IA).
- ✓ Familia CCN-STIC-887 Seguridad en AWS.
- ✓ Familia CCN-STIC-888 Seguridad en Google Cloud Platform. (Ej: CCN-STIC-888C Guía de Configuración Segura para Contenedores).

En <https://www.ccn-cert.cni.es/guias.html> puede estudiarse información más detallada de las guías actualizadas, tanto de la serie 800 como del resto de series.

## 2 ADECUACIÓN DE SISTEMAS AL ENS

En la disposición transitoria única del RD 311/2022 se indica:

- ✓ 24 meses desde la entrada en vigor (5/5/2022)

La forma de realizar dicha adecuación se encuentra desarrollada en la Guía CCN-STIC-806 (actualizada en junio de 2020). El Plan de Adecuación será elaborado por el Responsable de Seguridad del Sistema.

## 3 CATEGORIZACIÓN DEL SISTEMA DE ACUERDO AL ENS

Los activos podemos dividirlos en dos tipos: información y servicios. La determinación de la categoría de un sistema se efectuará en función de la valoración del impacto que tendría un incidente que afectará a la seguridad de esos activos con perjuicio para alguna de las dimensiones ACIDT.

Estas valoraciones corresponderán al Responsable de la Información o al Responsable del Servicio, según el tipo de activo. La categorización la realizará el Responsable del Sistema.

La asignación de una determinada categoría de seguridad determina el equilibrio entre la importancia de la información que maneja o los servicios que presta y el esfuerzo de seguridad requerido. Implica proporcionalidad entre los riesgos y las medidas de seguridad. Si una dimensión de seguridad no se ve afectada, no se adscribirá a ningún nivel.

| CRITERIOS COMUNES APLICABLES A TODAS LAS DIMENSIONES DE TIPOS DE INFORMACIÓN Y SERVICIOS |                               |                                                                                        |                                                                     |                                                                    |
|------------------------------------------------------------------------------------------|-------------------------------|----------------------------------------------------------------------------------------|---------------------------------------------------------------------|--------------------------------------------------------------------|
|                                                                                          | No aplicable (N/A)            | BAJO                                                                                   | MEDIO                                                               | ALTO                                                               |
|                                                                                          |                               | Perjuicio limitado                                                                     | Perjuicio grave                                                     | Perjuicio muy grave                                                |
| Capacidad de la entidad para lograr sus objetivos                                        | No existe un impedimento.     | Existe algún inconveniente leve para alcanzarlo, pero que es subsanable a corto plazo. | Existe una pérdida de la capacidad que es subsanable a medio plazo. | Existe una pérdida de la capacidad no subsanable a medio plazo.    |
| Activos entidades                                                                        | No existe perjuicio.          | Existe un perjuicio leve y subsanable.                                                 | Existe un daño importante, aunque subsanable.                       | Existe un daño grave de difícil o imposible reparación             |
| Cumplimiento de normativa                                                                | No implica un incumplimiento. | Incumplimiento leve de una regulación, de carácter subsanable.                         | Incumplimiento material de una regulación, no subsanable.           | Incumplimiento formal y material de una regulación, no subsanable. |

Nota: Incumplimiento formal implica que la ley o regulación se cumple, aunque con errores de forma. El incumplimiento material significa que no se cumple con la obligación expresada en la norma.

Si un sistema maneja diferentes informaciones y presta diferentes servicios, el nivel del sistema en cada dimensión será el mayor de los establecidos para esa dimensión en cada servicio. Por último, la categoría del sistema será la mayor de las categorías de todas sus dimensiones.

### VALORACIÓN DE LOS SERVICIOS E INFORMACIÓN

A continuación, se describen algunos ejemplos de criterios para establecer un valor en cada dimensión. Estos criterios son de carácter general y orientativo, pudiendo la política de seguridad concretar casos particulares de la entidad y que el responsable de la información y/o del servicio fundamente la adscripción que determine como apropiada.

- CONFIDENCIALIDAD: consecuencias que tendría su revelación a personas no autorizadas.
- INTEGRIDAD: consecuencias que tendría su modificación por alguien no autorizado a modificar la información.
- TRAZABILIDAD: consecuencias que tendría el no poder comprobar a posteriori quién ha accedido a, o modificado, una cierta información.
- AUTENTICIDAD: consecuencias que tendría el hecho de que la información no fuera auténtica.
- DISPONIBILIDAD: Consecuencias que tendría que una persona o sistema interconectado autorizado no pudiera usar el servicio cuando lo necesita dentro del periodo de prestación de servicio establecido y anunciado por la organización

Puesto que la categorización de un sistema puede ocasionar que las medidas a aplicar sean excesivas en algunos casos, es posible desagregarlo en varios subsistemas, siempre que puedan delimitarse la información y los servicios afectados.

Con carácter general, los requisitos de seguridad de otros sistemas que dependan de los servicios prestados por el sistema analizado, serán requisitos del sistema analizado. Si un sistema maneja información de terceros o presta servicio a terceros (un organismo público o una entidad privada), serán estos terceros los que deberán valorar la información o los servicios.

La categoría del sistema será la mayor de las categorías de las 5 dimensiones ACIDT.

Las medidas de seguridad se dividen en tres grupos:

- Marco organizativo - Relacionado con la organización global de la seguridad.
- Marco operacional - Protege la operación del sistema.
- Medidas de protección - Protegen un activo en concreto.

Las medidas seleccionadas utilizando el Anexo II constituirán la Declaración de Aplicabilidad, que deberá ser firmada por el Responsable de Seguridad.

Suele comenzarse por analizar los activos de tipo Información, dado que los activos de tipo Servicio heredarán de estos sus niveles de Confidencialidad e Integridad. Por otro lado, la dimensión Trazabilidad a menudo hereda su categoría de la dimensión Autenticación. En el caso de la Disponibilidad, se suele elegir el nivel en función del *Recovery Time Objective* (RTO): si es menor de 4h se considera ALTO; hasta las 24h MEDIO; hasta 1 semana BAJO; si es mayor de 1 semana SIN VALORACIÓN.

| IMPACTO                                   | BAJO                 | MEDIO                 | ALTO      |
|-------------------------------------------|----------------------|-----------------------|-----------|
| RTO (Tiempo de Recuperación del Servicio) | 1 día < RTO < 5 días | 4 horas < RTO < 1 día | < 4 horas |

Para aplicar las medidas de seguridad contempladas en el Anexo II previamente hay que hacer un Análisis de Riesgos con el objetivo de determinar los activos, amenazas, vulnerabilidades y el impacto. Para ello se puede utilizar la herramienta PILAR.

## 4 MEDIDAS DE SEGURIDAD

### 4.1 MARCO ORGANIZATIVO

Se aplican siempre (desde categoría básica). Implica la existencia de una Política, de Normativa y Procedimientos de Seguridad, así como de un Proceso de autorización para el uso de aplicaciones, equipos, instalaciones, medios, etc.

### 4.2 MARCO OPERACIONAL

En la tabla de las páginas siguientes, la columna “Por categoría o dimensiones” indica si la medida se exige atendiendo al nivel de seguridad de una o más dimensiones de seguridad, o atendiendo a la categoría de seguridad del sistema. Las celdas en amarillo indican que se empieza a aplicar en categoría media o superior. Las celdas en rojo son sólo de aplicación en categoría alta o requieren seguridad superior en categoría media.

|                   |                                          |           | Nivel de dimensiones de seguridad                                                                                                                |                                                                                              |                                                                             |
|-------------------|------------------------------------------|-----------|--------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------|
|                   |                                          |           | BAJO                                                                                                                                             | MEDIO                                                                                        | ALTO                                                                        |
|                   |                                          |           | Categoría del sistema de seguridad                                                                                                               |                                                                                              |                                                                             |
|                   |                                          |           | BÁSICA                                                                                                                                           | MEDIA                                                                                        | ALTA                                                                        |
| Planificación     | Análisis de riesgos                      | Categoría | Informal                                                                                                                                         | (+R1) Semiformal.                                                                            | (+R2) Formal.                                                               |
|                   | Arquitectura de seguridad                | Categoría | Documentada; esquema de líneas de defensa; sistema de identificación y autenticación de usuarios.                                                | (+R1) SGSI.                                                                                  | (+R1+R2+R3) Actualización y aprobación periódica SGSI y controles técnicos. |
|                   | Adquisición de nuevos componentes        | Categoría | Según las conclusiones del análisis de riesgos, acorde a la arquitectura y teniendo en cuenta necesidades técnicas, de formación y financiación. |                                                                                              |                                                                             |
|                   | Dimensionamiento/gestión de la capacidad | D         | Estudio de necesidades relativas a procesamiento, almacenamiento, comunicación, personal e instalaciones.                                        | (+R1) Mejora continua.                                                                       |                                                                             |
|                   | Componentes certificados                 | Categoría | No aplica.                                                                                                                                       | Según el CPSTIC <sup>1</sup> del CCN. Refuerzo con medidas TEMPEST y lista de componente SW. |                                                                             |
| Control de Acceso | Identificación                           | T A       | Sistemas previstos en ley 39/2015.                                                                                                               | (+R1) Identificación avanzada.                                                               |                                                                             |
|                   | Requisitos de acceso                     | C I T A   | El acceso a los recursos estará limitado a los derechos que establezca el responsable del recurso.                                               | (+R1) Implementación de privilegios.                                                         |                                                                             |

<sup>1</sup> CPSTIC: Catálogo de Productos de Seguridad TIC

|                   |                                                          |           |                                                                                                                                                                                                                      |                                                                                                                                                                                                                         |                                                                                                                 |
|-------------------|----------------------------------------------------------|-----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------|
|                   | Segregación de funciones y tareas                        | C I T A   | No aplica.                                                                                                                                                                                                           | Una tarea crítica necesita de 2 o más personas. Desarrollo y operación, autorización y control en personas distintas.                                                                                                   | (+R1) Segregación rigurosa.                                                                                     |
|                   | Procesos de gestión de derechos de acceso                | C I T A   | Atiende a los principios de:<br>Acceso prohibido por defecto; Mínimo privilegio; Conocer y compartir la información necesaria e indispensable; Revisión periódica; Política de acceso específica para acceso remoto. |                                                                                                                                                                                                                         |                                                                                                                 |
|                   | Mecanismo de autenticación (usuarios externos)           | C I T A   | (+[R1   R2   R3   R4])<br>Gestión de credenciales.<br>R1 = Contraseñas.                                                                                                                                              | (+[R2   R3   R4]+R5)<br>R2 = Contraseña + OTP <sup>2</sup> .<br>R3 = Certificado + 2FA <sup>3</sup> + Registro previo presencial o telemático.<br>R4 = Certificados en dispositivo físico.<br>R5 = Registro de accesos. |                                                                                                                 |
|                   | Mecanismo de autenticación (usuarios de la organización) | C I T A   | (+[R1   R2   R3   R4]+R8+R9)<br>R8 = 2FA desde zona no controlada (Internet).<br>R9 = Acceso remoto.                                                                                                                 | (+[R1   R2   R3   R4]+R5+R8+R9)                                                                                                                                                                                         | (+[R1   R2   R3   R4]+R5+R6+R7+R8+R9)<br>R6 = Ventana de acceso.<br>R7 = Suspensión por no utilización.         |
| Explotación       | Inventario de activos                                    | Categoría | Actualizado con responsable de cada activo identificado (lista de componentes no es obligatorio, pero sí muy necesario).                                                                                             |                                                                                                                                                                                                                         |                                                                                                                 |
|                   | Configuración de seguridad                               | Categoría | Cuentas estándar deshabilitadas y mínima funcionalidad.                                                                                                                                                              |                                                                                                                                                                                                                         |                                                                                                                 |
|                   | Gestión de la configuración de seguridad                 | Categoría | Continuamente.                                                                                                                                                                                                       | (+R1)<br>Mantenimiento regular de la configuración.                                                                                                                                                                     | (+R1+R2+R3)<br>Responsable de configuración y copias de seguridad.                                              |
|                   | Mantenimiento y actualizaciones de seguridad             | Categoría | Seguimiento continuo, aplicación de parches / actualizaciones priorizada.                                                                                                                                            | (+R1)<br>Pruebas en preproducción.                                                                                                                                                                                      | (+R1+R2)<br>Prevención de fallos.                                                                               |
|                   | Gestión de cambios                                       | Categoría | No aplica.                                                                                                                                                                                                           | Planificación y pruebas de aceptación.                                                                                                                                                                                  | (+R1)<br>Prevención de fallos.                                                                                  |
|                   | Protección frente a código dañino                        | Categoría | Software de detección en tiempo real en todos los equipos.                                                                                                                                                           | (+R1+R2)<br>Escaneo periódico y revisión preventiva.                                                                                                                                                                    | (+R1+R2+R3+R4)<br>Lista blanca y respuesta a incidente (EDR <sup>4</sup> ).                                     |
|                   | Gestión de incidentes                                    | Categoría | Proceso integral atendiendo a lo dispuesto en la LOPDGDD.                                                                                                                                                            | (+R1+R2)<br>Notificación y detección y respuesta.                                                                                                                                                                       | (+R1+R2+R3)<br>Reconfiguración dinámica.                                                                        |
|                   | Registro de la actividad                                 | T         | Registro de auditoría.                                                                                                                                                                                               | (+R1+R2+R3+R4)<br>Revisión de registros;<br>Sincronización del reloj del sistema; Retención de registros; Control de acceso.                                                                                            | (+R1+R2+R3+R4+R5)<br>Revisión automática y correlación de eventos.                                              |
|                   | Registro de la gestión de incidentes                     | Categoría | Se registran los informes y las evidencias relacionadas con un incidente.                                                                                                                                            |                                                                                                                                                                                                                         |                                                                                                                 |
|                   | Protección de claves criptográficas                      | Categoría | Protegidas a lo largo de todo el ciclo de vida.                                                                                                                                                                      | (+R1)<br>Algoritmos y parámetros autorizados por el CCN.                                                                                                                                                                |                                                                                                                 |
| Recursos externos | Contratación y SLAs                                      | Categoría | No aplica.                                                                                                                                                                                                           | En la utilización de recursos externos se establece contractualmente un SLA (servicio mínimo admisible).                                                                                                                |                                                                                                                 |
|                   | Gestión diaria                                           | Categoría | No aplica.                                                                                                                                                                                                           | Medición de obligaciones de servicio.                                                                                                                                                                                   |                                                                                                                 |
|                   | Protección de la cadena de suministro                    | Categoría | No aplica.                                                                                                                                                                                                           | No aplica.                                                                                                                                                                                                              | Análisis de impacto, estimación de riesgo y medidas de contención ante un incidente en la cadena de suministro. |
|                   | Interconexión de sistemas                                | Categoría | No aplica.                                                                                                                                                                                                           | Intercambio de información y prestación de servicios con otros sistemas.                                                                                                                                                | (+R1)<br>Coordinación de actividades.                                                                           |

<sup>2</sup> OTP: One Time Password

<sup>3</sup> 2FA: 2 Factor Authentication

<sup>4</sup> EDR: Endpoint Detection and Response

|                            |                                    |           |                                                                                                                                                          |                                                                                                                  |                                                                                                                   |
|----------------------------|------------------------------------|-----------|----------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| Servicios en la nube       | Protección de servicios en la nube | Categoría | Los prestadores de servicio han de cumplir medidas de seguridad definidas en guías CCN-STIC (auditoría, transparencia, cifrado y jurisdicción de datos). | (+R1)<br>Servicios certificados.                                                                                 | (+R1+R2)<br>Guías de configuración de seguridad específicas.                                                      |
| Continuidad del servicio   | Análisis de impacto                | D         | No aplica.                                                                                                                                               | Determinación de los elementos críticos en la prestación de servicio y el impacto de una interrupción.           |                                                                                                                   |
|                            | Plan de continuidad                | D         | No aplica.                                                                                                                                               | No aplica.                                                                                                       | Identificación de funciones, responsabilidades y actividades; previsión de medios alternativos.                   |
|                            | Pruebas periódicas                 | D         | No aplica.                                                                                                                                               | No aplica.                                                                                                       | Búsqueda de errores o deficiencias del plan de continuidad.                                                       |
|                            | Medios alternativos                | D         | No aplica.                                                                                                                                               | No aplica.                                                                                                       | Disponibilidad de los medios alternativos, tiempo máximo de activación.                                           |
| Monitorización del sistema | Detección de intrusión             | Categoría | Se dispondrá de herramientas de detección.                                                                                                               | (+R1)<br>Detección basada en reglas.                                                                             | (+R1+R2)<br>Procedimientos de respuesta.                                                                          |
|                            | Sistemas de métricas               | Categoría | Recopilación de datos para conocer el grado de implantación de medidas de seguridad (informe anual del art. 32).                                         | (+R1+R2)<br>Efectividad del sistema de gestión de incidentes. Eficiencia del sistema de gestión de la seguridad. |                                                                                                                   |
|                            | Vigilancia                         | Categoría | Se dispondrá de sistema automático de recolección de eventos de seguridad.                                                                               | (+R1+R2)<br>Correlación de eventos<br>Análisis dinámico de vulnerabilidades en la superficie de exposición.      | (+R1+R2+R3+R4+R5+R6)<br>APTs <sup>5</sup> ; Observatorios digitales; Minería de datos; Inspecciones de seguridad. |

### 4.3 MEDIDAS DE PROTECCIÓN

|                                                    |                                                                      |           | BAJO                                                                                                                           | MEDIO                                                                                                                                                                                      | ALTO |
|----------------------------------------------------|----------------------------------------------------------------------|-----------|--------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| Protección de las instalaciones e infraestructuras | Áreas separadas con control de acceso                                | Categoría | CPD organizado por áreas específicas para su función y control de acceso a las mismas.                                         |                                                                                                                                                                                            |      |
|                                                    | Identificación de personas                                           | Categoría | Registro de entrada y salida de personas a instalaciones del CPD.                                                              |                                                                                                                                                                                            |      |
|                                                    | Acondicionamiento de locales                                         | Categoría | El CPD asegura condiciones de temperatura, humedad, protección del cableado y de amenazas identificadas en gestión de riesgos. |                                                                                                                                                                                            |      |
|                                                    | Energía eléctrica                                                    | D         | Tomas eléctricas y luces de emergencia en el CPD.                                                                              | (+R1)<br>Suministro eléctrico de emergencia.                                                                                                                                               |      |
|                                                    | Protección frente a incendios                                        | D         | Atendiendo a la normativa industrial.                                                                                          |                                                                                                                                                                                            |      |
|                                                    | Protección frente a inundaciones                                     | D         | No aplica.                                                                                                                     | CPD protegido frente a incidentes causados por agua.                                                                                                                                       |      |
|                                                    | Registro de entrada y salida de equipamiento                         | Categoría | Anotación de entradas y salidas de equipamiento esencial identificando a la persona que lo autoriza.                           |                                                                                                                                                                                            |      |
| Gestión personal                                   | Caracterización de puesto de trabajo (HPS <sup>6</sup> recomendable) | Categoría | No aplica.                                                                                                                     | Definición de responsabilidades en materia de seguridad y de requisitos que han de satisfacer las personas que ocupen el puesto de trabajo, en particular, relativo a la confidencialidad. |      |
|                                                    | Deberes y obligaciones                                               | Categoría | Información al trabajador de responsabilidades, confidencialidad y medidas disciplinarias.                                     | (+R1)<br>Confirmación expresa.                                                                                                                                                             |      |
|                                                    | Concienciación                                                       | Categoría | Regularmente se ha de concienciar al personal acerca de su papel y responsabilidad en cuanto a la seguridad del sistema.       |                                                                                                                                                                                            |      |
|                                                    | Formación                                                            | Categoría | Formación del personal de forma regular en materias de seguridad.                                                              |                                                                                                                                                                                            |      |

<sup>5</sup> APT: Advanced Persistent Threat

<sup>6</sup> HPS: Habilitación Personal de Seguridad

|                                             |                                                                                              |           |                                                                                                                                                                                                                                            |                                                                                                                                                                                                                                                   |                                                                                                                   |
|---------------------------------------------|----------------------------------------------------------------------------------------------|-----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| Protección de los equipos                   | Puesto de trabajo despejado                                                                  | Categoría | Únicamente el material necesario en cada momento.                                                                                                                                                                                          | (+R1)<br>Almacenamiento del material en lugar cerrado.                                                                                                                                                                                            |                                                                                                                   |
|                                             | Bloqueo de puesto de trabajo (Guía asociada al perfil de cumplimiento o a la categorización) | A         | No aplica.                                                                                                                                                                                                                                 | Bloqueo del terminal tras tiempo prudencial sin actividad.                                                                                                                                                                                        | (+R1)<br>Cierre de sesiones.                                                                                      |
|                                             | Protección de dispositivos portátiles                                                        | Categoría | Protección de dispositivos que salgan de las instalaciones. Inventario y procedimiento ante pérdidas.                                                                                                                                      | Protección de dispositivos que salgan de las instalaciones de la unidad. Inventario y procedimiento ante pérdidas.                                                                                                                                | (+R1+R2)<br>Cifrado de discos.<br>Uso de dispositivos restringido a entornos protegidos.                          |
|                                             | Otros dispositivos conectados a la red.                                                      | C         | Impresoras, escáneres, proyectores, altavoces, IoT, BYOD, configurados de manera segura que garantice el flujo de información de E/S.                                                                                                      | (+R1)<br>Productos certificados.                                                                                                                                                                                                                  |                                                                                                                   |
| Protección de las comunicaciones            | Perímetro seguro                                                                             | Categoría | Debe existir un sistema de protección perimetral que separe la red interna del exterior (ver ITS de Interconexión de SI).                                                                                                                  |                                                                                                                                                                                                                                                   |                                                                                                                   |
|                                             | Protección de la confidencialidad                                                            | C         | Uso de VPN cuando la comunicación discorra por redes fuera del dominio de seguridad.                                                                                                                                                       | (+R1)<br>Algoritmos y parámetros autorizados.                                                                                                                                                                                                     | (+R1+R2+R3)<br>R2 = Dispositivos hardware.<br>R3 = Productos certificados.                                        |
|                                             | Protección de la integridad y de la autenticidad                                             | I A       | Asegurar la autenticidad en comunicaciones con un punto exterior al dominio de seguridad. Prevención de ataques activos al ser detectados: modificación de información en tránsito, inyección de información espuria, secuestro de sesión. | (+R1+R2)<br>R1 = VPN.<br>R2 = Uso de algoritmos y parámetros autorizados por el CCN.                                                                                                                                                              | (+R1+R2+R3+R4)<br>R3 = Dispositivos hardware.<br>R4 = Productos certificados.                                     |
|                                             | Separación de flujos de información en la red.                                               | Categoría | No aplica.                                                                                                                                                                                                                                 | (+[R1 R2 R3])<br>Tráfico de red segregado.<br>R1 = Segmentación lógica básica (VLANs) de usuarios, servicios y administración.                                                                                                                    | (+[R2 R3]+R4)<br>R2 = Segmentación lógica avanzada.<br>R3 = Segmentación física.<br>R4 = Puntos de interconexión. |
| Protección de los soportes de información   | Marcado de soportes                                                                          | C         | No aplica.                                                                                                                                                                                                                                 | Los soportes de información llevarán marcas o metadatos que indiquen el nivel de seguridad de la información.                                                                                                                                     |                                                                                                                   |
|                                             | Criptografía                                                                                 | C I       | No aplica.                                                                                                                                                                                                                                 | Aplica a soportes de información removible. Uso de algoritmos y parámetros autorizados por el CCN.                                                                                                                                                | (+R1+R2)<br>R1 = Productos certificados.<br>R2 = Copias de seguridad.                                             |
|                                             | Custodia                                                                                     | Categoría | Control de acceso con medidas físicas o lógicas a los soportes de información. Respeto por las condiciones atmosféricas requeridas por el fabricante.                                                                                      |                                                                                                                                                                                                                                                   |                                                                                                                   |
|                                             | Transporte                                                                                   | Categoría | Los dispositivos que son desplazados de lugar han de cumplir los requisitos de seguridad permaneciendo siempre bajo control.                                                                                                               |                                                                                                                                                                                                                                                   |                                                                                                                   |
|                                             | Borrado y destrucción                                                                        | C         | Aplica a todo tipo de equipos y soportes que almacenen información.                                                                                                                                                                        | (+R1)<br>Productos certificados.                                                                                                                                                                                                                  |                                                                                                                   |
| Protección de las aplicaciones informáticas | Desarrollo de aplicaciones                                                                   | Categoría | No aplica.                                                                                                                                                                                                                                 | (+R1+R2+R3+R4))<br>El entorno de desarrollo debe ser distinto al de producción sin compartir datos entre ellos.<br>R1 = Mínimo privilegio.<br>R2 = Metodología de desarrollo seguro.<br>R3 = Seguridad desde el diseño.<br>R4 = Datos de pruebas. |                                                                                                                   |
|                                             | Aceptación y puesta en servicio                                                              | Categoría | Antes del paso a producción se comprobará el correcto funcionamiento de la aplicación.                                                                                                                                                     | (+R1)<br>Pruebas realizadas en entorno de preproducción.                                                                                                                                                                                          |                                                                                                                   |
| Protección de la información                | Datos personales                                                                             | Categoría | El Responsable de Seguridad recogerá los requisitos de protección de datos fijados por el Responsable del Tratamiento para implantarlos en el sistema, así como riesgos para derechos y libertades según el art. 24 y el art. 32 del RGPD. |                                                                                                                                                                                                                                                   |                                                                                                                   |
|                                             | Calificación de la información                                                               | C         | No aplica.                                                                                                                                                                                                                                 | Para calificar la información se tendrá en cuenta lo establecido en leyes y tratados internacionales. La información no clasificada se califica como: USO OFICIAL.                                                                                |                                                                                                                   |

|                         |                                            |           |                                                                                                                                                                                  |                                                                                                                   |                                                                                                                                                  |
|-------------------------|--------------------------------------------|-----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| Protección de servicios | Firma electrónica                          | I A       | Verificación y validación de firma electrónica durante el tiempo requerido por la actividad administrativa.                                                                      | (+R1+R2+R3)<br>R1 = Certificados cualificados.<br>R2 = Algoritmos y parámetros autorizados.                       | (+R1+R2+R3+R4)<br>R3 = Verificación y validación de firma.<br>R4 = Firma electrónica avanzada basada en certificados cualificados junto con 2FA. |
|                         | Sellos de tiempo                           | T         | No aplica.                                                                                                                                                                       | No aplica.                                                                                                        | Aplicados si se necesita evidencia electrónica en el futuro.                                                                                     |
|                         | Limpieza de documentos                     | C         | Retirada de información adicional en campos ocultos, metadatos, comentarios o revisiones.                                                                                        |                                                                                                                   |                                                                                                                                                  |
|                         | Copias de seguridad                        | D         | La periodicidad y plazos de retención se determinan en la normativa interna de la organización.                                                                                  | (+R1)<br>Pruebas de recuperación.                                                                                 | (+R1+R2)<br>Protección de las copias de seguridad.                                                                                               |
|                         | Protección del correo electrónico          | Categoría | Proteger a la organización de spam, código dañino, applets. Limitar el uso como soporte de comunicaciones privadas. Formación y concienciación.                                  |                                                                                                                   |                                                                                                                                                  |
|                         | Protección de servicios y aplicaciones web | Categoría | (+R1   R2)<br>Control de acceso a información que lo requiera. Prevención de ataques: modificación de URL, RFI <sup>7</sup> , robo de cookies, SQL injection, XSS <sup>8</sup> . | (+R1   R2)<br>R1 = Auditorías de seguridad.<br>R2 = Auditorías de seguridad avanzada.                             | (+R2+R3)<br>R3 = Protección de las cachés.                                                                                                       |
|                         | Protección de la navegación web            | Categoría | La navegación por Internet de usuarios internos se protegerá con normativa de utilización, formación y concienciación y evitando visitas a webs maliciosas.                      |                                                                                                                   | (+R1)<br>Monitorización.                                                                                                                         |
|                         | Protección frente a denegación de servicio | D         | No aplica.                                                                                                                                                                       | Medidas preventivas<br>Sistema dimensionado con holgura y tecnologías instaladas que prevengan ataques conocidos. | (+R1)<br>Detección y reacción.                                                                                                                   |

## 5 INSTRUCCIONES TÉCNICAS DE SEGURIDAD (ITS)

Actualmente hay 4:

- Informe del estado de la seguridad (actualizada en 2020).
- Notificación de incidentes de seguridad (publicada en 2018).
- Auditoría de la seguridad de los sistemas de información (publicada en 2018).
- Conformidad con el ENS (publicada en 2016).

Las ITS se pueden encontrar en:

<https://administracionelectronica.gob.es/pae/Home/pae/Estrategias/pae/Seguridad/Inicio/Instruccion-es-Tecnicas.html>

*Disposición Adicional segunda ENS (**modificada por RD 1125/2024**): La persona titular del Ministerio para la Transformación Digital y de la Función Pública, a propuesta de la CSAE y a iniciativa del CCN, aprobará las instrucciones técnicas de seguridad de obligado cumplimiento, que se publicarán mediante Resolución de la persona titular de la Secretaría de Estado de Función Pública.*

### 5.1 ITS DE INFORME DEL ESTADO DE LA SEGURIDAD

Establece las condiciones relativas a la recopilación y comunicación de datos que permitan conocer las principales variables de la seguridad de la información de los sistemas comprendidos en el ámbito de aplicación del ENS, y confeccionar un perfil general del estado de la ciberseguridad en las AAPP, al objeto de dar adecuada respuesta al mandato del artículo 32 del ENS. Para ello, el CCN ha desarrollado el Informe Nacional del Estado de Seguridad (la herramienta **INES**), que facilita la labor de todos los organismos.

<sup>7</sup> RFI: Remote File Injection

<sup>8</sup> XSS: Cross-Site Scripting

El detalle queda recogido en las siguientes guías CCN-STIC:

- ✓ CCN-STIC-815. Indicadores y métricas en el ENS.
- ✓ CCN-STIC-824. Informe nacional del estado de seguridad de los sistemas TIC. Es aquí donde se indica que **se prevé recopilar** las métricas (medidas de seguridad op.mon.2) **anualmente**.
- ✓ CCN-STIC-844. Manual de Usuario de INES.

## 5.2 ITS DE CONFORMIDAD CON EL ENS

Establece los criterios y procedimientos para la determinación de la conformidad con el ENS y para la publicidad de dicha conformidad, al objeto de poder dar adecuada respuesta al mandato del Capítulo V, Normas de conformidad, del Real Decreto 311/2022; en particular, determina los mecanismos de obtención y ulterior publicidad de las declaraciones de conformidad y los distintivos de seguridad de los que sean acreedores y que se hubieren obtenido respecto al cumplimiento del ENS. SE puede encontrar más información sobre esta cuestión en la Guía CCN-STIC-809 Declaración, Certificación y Aprobación Provisional de conformidad con el ENS y Distintivos de cumplimiento.

De acuerdo al ENS, los sistemas de categoría **BÁSICA** sólo requerirán de una **autoevaluación** para su declaración de conformidad, mientras que los sistemas de categoría **MEDIA O ALTA** precisarán de una **auditoría formal** para su certificación de conformidad. Tanto la autoevaluación como la auditoría formal se realizarán **al menos cada 2 años**.

En la ITS se especificará además cómo se dará **publicidad** a la conformidad:

- BÁSICA exponiendo el Distintivo de Declaración de Conformidad en la sede electrónica, que incluirá un enlace al documento de Declaración de Conformidad correspondiente, que también permanecerá accesible a través de dicha sede electrónica.
- MEDIA y ALTA lo mismo, solo que en este caso la conformidad será expedida por una entidad certificadora y se completará mediante un Distintivo de Certificación de Conformidad.

Las entidades certificadoras serán acreditadas por la Entidad Nacional de Acreditación en España (ENAC). A continuación, se muestran algunos distintivos de Certificación de Conformidad con el ENS



## 5.3 ITS DE NOTIFICACIÓN DE INCIDENTES DE SEGURIDAD

Se publica mediante la Resolución de 13 de abril de 2018, de la Secretaría de Estado de Función Pública, por la que se aprueba la ITS de notificación de incidentes de seguridad. Esta establece los criterios y procedimientos para la notificación al CCN por parte de las entidades que forman parte de los ámbitos subjetivos de aplicación de las leyes 39/2015 y 40/2015 de aquellos incidentes que tengan un impacto significativo en la seguridad de la información que manejan y los servicios que prestan en relación con la categoría del sistema.

La notificación será obligatoria en el caso de incidentes con nivel de impacto Alto, Muy alto y Crítico. La instrucción también determina las evidencias a entregar en el caso de incidentes nivel Alto, Muy alto y

Crítico, la obligación de remisión de estadísticas de incidentes, la notificación de impactos recibidos, el desarrollo de herramientas automatizadas para facilitar las notificaciones y el régimen legal de las notificaciones y comunicación de información, más una disposición adicional con precisiones sobre la notificación cuando el incidente afecte a datos personales. Sus aspectos más relevantes son la determinación de:

#### 5.4 ITS DE AUDITORÍA DE SEGURIDAD DE SISTEMAS DE INFORMACIÓN

Se publica mediante la Resolución de 27 de marzo de 2018, de la Secretaría de Estado de Función Pública, por la que se aprueba la ITS de auditoría de la seguridad de los sistemas de información. Tiene por objeto establecer las condiciones para la realización de las auditorías, ordinarias o extraordinarias, previstas en el artículo 31 del ENS. Las auditorías deben realizarse para determinar el grado de conformidad con el ENS y deben permitir a sus responsables adoptar las medidas oportunas para subsanar las deficiencias encontradas y, en su caso, posibilitar la obtención de la correspondiente **certificación de conformidad**.

Cabe recordar que, para obtener esta certificación, los sistemas de información de categoría MEDIA o ALTA precisarán superar una auditoría de seguridad, al menos cada dos años. Asimismo, los **informes de auditoría** emitidos podrán ser requeridos por el CCN-CERT ante cualquier agresión recibida en los sistemas de información de las AAPP.

Para el desarrollo de las auditorías, la Resolución señala que deberán realizarse conforme a la propia ITS y, cuando corresponda, a las normas nacionales e internacionales sobre auditorías, entre ellas:

- ✓ Guía CCN-STIC-802 Auditoría del ENS.
- ✓ Guía CCN-STIC-804 ENS. Guía de implantación.
- ✓ Guía CCN-STIC-808 Verificación del cumplimiento de las medidas en el ENS.

## 6 DIRECTIVA NIS2, UN ALTO NIVEL DE SEGURIDAD COMÚN EN LA UE

Conocida también como NIS2 (o Directiva SRI 2), el 27 de diciembre de 2022 se publicó la Directiva (UE) 2022/2555 del Parlamento Europeo y del Consejo, de 14 de diciembre de 2022, relativa a las medidas destinadas a garantizar un elevado nivel común de ciberseguridad en toda la Unión, por la que se modifican el Reglamento (UE) 910/2014 y la Directiva (UE) 2018/1972, y por la que se deroga la Directiva (UE) 2016/1148 (Directiva SRI o NIS).

La directiva NIS2 propone sustituir la directiva NIS y reforzar así los requisitos de seguridad, abordar la seguridad de las cadenas de suministro, racionalizar las obligaciones de información e introducir medidas de supervisión más rigurosas y requisitos de aplicación más estrictos, incluyendo sanciones armonizadas en toda la UE. La propuesta de ampliación del ámbito de aplicación de la NIS2, obligando efectivamente a más entidades y sectores a tomar medidas, contribuiría a aumentar el nivel de ciberseguridad en Europa a largo plazo.

La propuesta de NIS2 se fija 3 objetivos generales:

- 1) Aumentar el nivel de ciberresiliencia de un amplio conjunto de empresas que operan en la UE en todos los sectores relevantes, estableciendo normas que garanticen que todas las entidades públicas y privadas del mercado interior (que cumplen funciones importantes para la economía y la sociedad en su conjunto) estén obligadas a adoptar medidas adecuadas de ciberseguridad. Por ejemplo, la propuesta amplía considerablemente el ámbito de la directiva actual, añadiendo nuevos sectores como las telecomunicaciones, las plataformas de medios sociales y la administración pública. Establece que todas las medianas y las grandes entidades activas que operan en los sectores cubiertos por el marco NIS2 tienen que cumplir con las reglas de seguridad de la propuesta, y elimina la posibilidad de que los Estados miembros adapten los requisitos en determinados casos (lo que había provocado una gran fragmentación con la aplicación de NIS1). Se suprime la distinción que se hacía entre los operadores de servicios esenciales (OES) y los

proveedores de servicios digitales (DSP), que actualmente se dividen en tres categorías: mercados en línea, motores de búsqueda y proveedores de servicios en la nube. Por último, se aborda por primera vez la ciberseguridad de la cadena de suministro de las TIC (de especial importancia en el caso del IoT).

- 2) Reducir las incoherencias en materia de resiliencia en el mercado interior en los sectores ya cubiertos por la directiva, alineando más:
  - i. el ámbito de aplicación de facto
  - ii. los requisitos de seguridad y notificación de incidentes
  - iii. las disposiciones que rigen la supervisión nacional y su aplicación
  - iv. las capacidades de las autoridades competentes de los Estados miembros.

La propuesta incluye una lista de 7 elementos clave que todas las empresas deben abordar o aplicar como parte de las medidas que adopten, incluida la respuesta a incidentes, la seguridad de la cadena de suministro, el cifrado y la divulgación de vulnerabilidades. Además, la propuesta prevé un enfoque en dos fases para la notificación de incidentes. Las empresas afectadas tienen 24 horas desde que tienen conocimiento de un incidente para presentar un informe inicial, seguido de un informe final a más tardar un mes después. En cuanto a la aplicación, establece una lista mínima de sanciones administrativas siempre que las entidades infrinjan las normas relativas a la gestión de los riesgos de ciberseguridad o sus obligaciones de notificación establecidas en la Directiva NIS. Estas sanciones incluyen instrucciones vinculantes, la orden de aplicar las recomendaciones de una auditoría de seguridad, la orden de adecuar las medidas de seguridad a los requisitos de la NIS, y multas administrativas (de hasta 10 millones de euros o el 2 % del volumen de negocios total de las entidades en todo el mundo, lo que sea mayor).

- 3) Mejorar el nivel de conocimiento conjunto de la situación y la capacidad colectiva de prepararse y responder:
  - i. tomando medidas para aumentar el nivel de confianza entre autoridades competentes
  - ii. compartiendo más información
  - iii. estableciendo normas y procedimientos en caso de incidente o crisis a gran escala.

Las nuevas normas propuestas mejoran la forma en que la UE previene, gestiona y responde a los incidentes y crisis de ciberseguridad a gran escala, introduciendo responsabilidades claras, una planificación adecuada y una mayor cooperación de la UE. La directiva revisada establecería un marco de gestión de crisis de la UE, exigiendo a los Estados miembros que adopten un plan y designen a las autoridades nacionales competentes para participar en la respuesta a incidentes y crisis de ciberseguridad a nivel de la UE. La directiva propuesta crearía una Red de Organización de Enlace para Crisis Cibernéticas (EU-CyCLONe) para apoyar la gestión coordinada de los incidentes de ciberseguridad en toda la UE, así como para garantizar el intercambio de información. La directiva propuesta también reforzará el papel del Grupo de Cooperación NIS en la toma de decisiones y en el aumento de la cooperación entre Estados miembros. Los Estados miembros seguirán estando obligados a adoptar una estrategia nacional de ciberseguridad y designar una o varias autoridades nacionales competentes para supervisar el cumplimiento de la Directiva, y designar un *Computer Security Incident Response Team* (CSIRT) para gestionar las notificaciones de incidentes y puntos de contacto únicos (SPOC) para actuar como punto de enlace con otros Estados miembros.

## 7 OTRA NORMATIVA EUROPEA APLICABLE A LA SEGURIDAD

**Reglamento (UE) 2019/881** (Reglamento de Ciberseguridad):

- **Refuerzo del papel de ENISA:** La Agencia se vuelve permanente y recibe más recursos y competencias para actuar proactivamente, ayudar en la gestión de crisis y fomentar la cooperación.

- Marco para la creación de **esquemas europeos de certificación** de la ciberseguridad, a efectos de garantizar un nivel adecuado de ciberseguridad de los productos, servicios y procesos de TIC en la Unión, así como de evitar la fragmentación del mercado interior respecto a los esquemas de certificación de la ciberseguridad en la Unión.

**Reglamento (UE) 2022/2554 DORA** (Digital Operational Resilience Act): Obliga a las entidades financieras de la UE a asegurar su resiliencia operativa digital, reforzando la ciberseguridad, la gestión de riesgos TIC y la supervisión de proveedores externos.

**Reglamento (UE) 2025/38** (Reglamento de Ciberseguridad):

Establece la creación de:

- Red paneuropea de centros cibernéticos (en lo sucesivo, «Sistema Europeo de Alerta de Ciberseguridad») a fin de desarrollar y mejorar las capacidades coordinadas de detección y la conciencia situacional común.
- Mecanismo de Emergencia en materia de Ciberseguridad para ayudar a los Estados miembros a prepararse para incidentes de ciberseguridad significativos, a gran escala y equivalentes a gran escala, y a responder a ellos, atenuar sus repercusiones y e iniciar la recuperación de ellos, así como ayudar a otros usuarios a responder a incidentes de ciberseguridad significativos y equivalentes **a gran escala**.
- Mecanismo Europeo de Revisión de Incidentes de Ciberseguridad para revisar y evaluar incidentes de ciberseguridad significativos o **a gran escala**.

**Reglamento (UE) 2024/2847** (Reglamento de Ciberresiliencia):

- Establece requisitos obligatorios de ciberseguridad para todos los productos con elementos digitales (hardware y software) comercializados en el mercado único europeo, incluyendo dispositivos conectados, aplicaciones, firmware y componentes.

## 8 ESTRATEGIA DE SEGURIDAD NACIONAL

Tras la estrategia de 2017, la nueva estrategia ha sido publicada en 2021. Está estructurada en 5 capítulos:

- 1) Seguridad global y vectores de transformación.
- 2) Una España segura y resiliente.
- 3) Riesgos y amenazas.
- 4) Un planeamiento estratégico integrado.
- 5) Un Sistema de Seguridad Nacional y la Gestión de Crisis.

### 8.1 SEGURIDAD GLOBAL Y VECTORES DE TRANSFORMACIÓN (CAP. 1)



## 8.2 UNA ESPAÑA SEGURA Y RESILIENTE (CAP. 2)

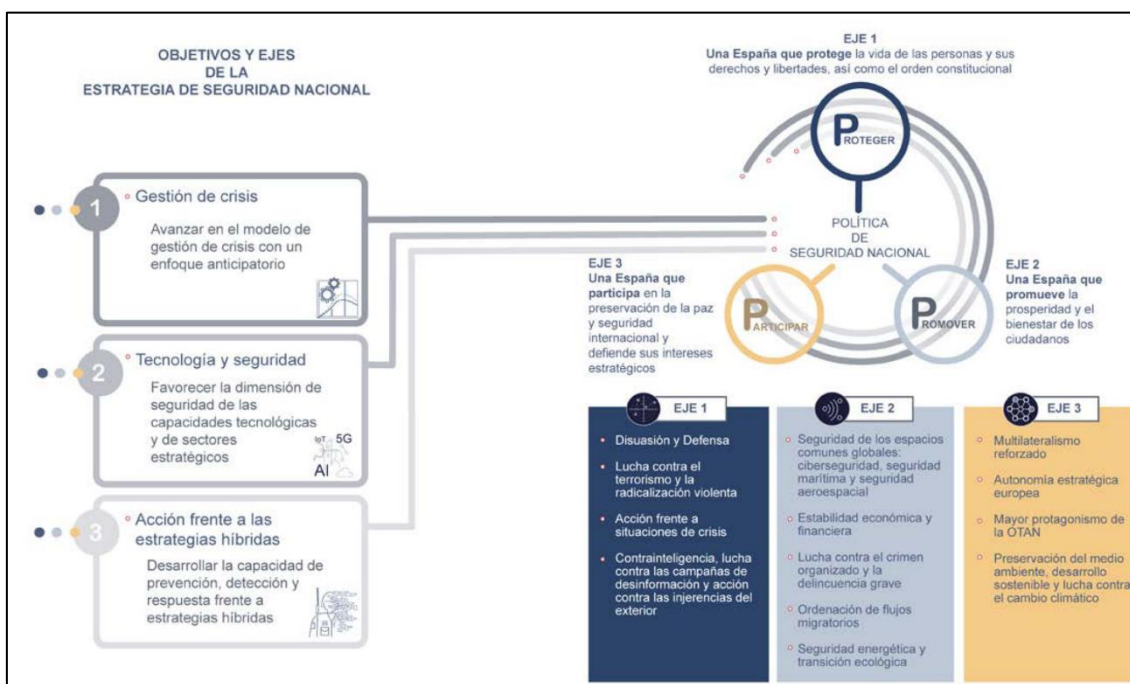
El segundo capítulo ofrece un recorrido de las distintas regiones del mundo, trazando un perfil desde la perspectiva española de la seguridad. Desde su identificación como país de condición europea, mediterránea y atlántica, se realiza un recorrido geográfico, donde Europa, Magreb y Oriente Próximo, África Subsahariana, América del Norte, América Latina y el Caribe, y Asia-Pacífico se analizan desde el prisma de la Seguridad Nacional.

## 8.3 RIESGOS Y AMENAZAS A LA SEGURIDAD NACIONAL (CAP. 3)

El tercer capítulo describe un mapa de los riesgos y amenazas a la Seguridad Nacional con un enfoque que pone de relieve su dinamismo e interdependencia, en un entorno donde las estrategias híbridas ganan protagonismo. Los riesgos y las amenazas a la Seguridad Nacional no son estáticos, sino que se conciben de una manera dinámica, ya que la interrelación entre ellos puede producir efectos en cascada, como ha ocurrido con la crisis generada por la pandemia.

## 8.4 UN PLANTEAMIENTO ESTRATÉGICO INTEGRADO (CAP. 4)

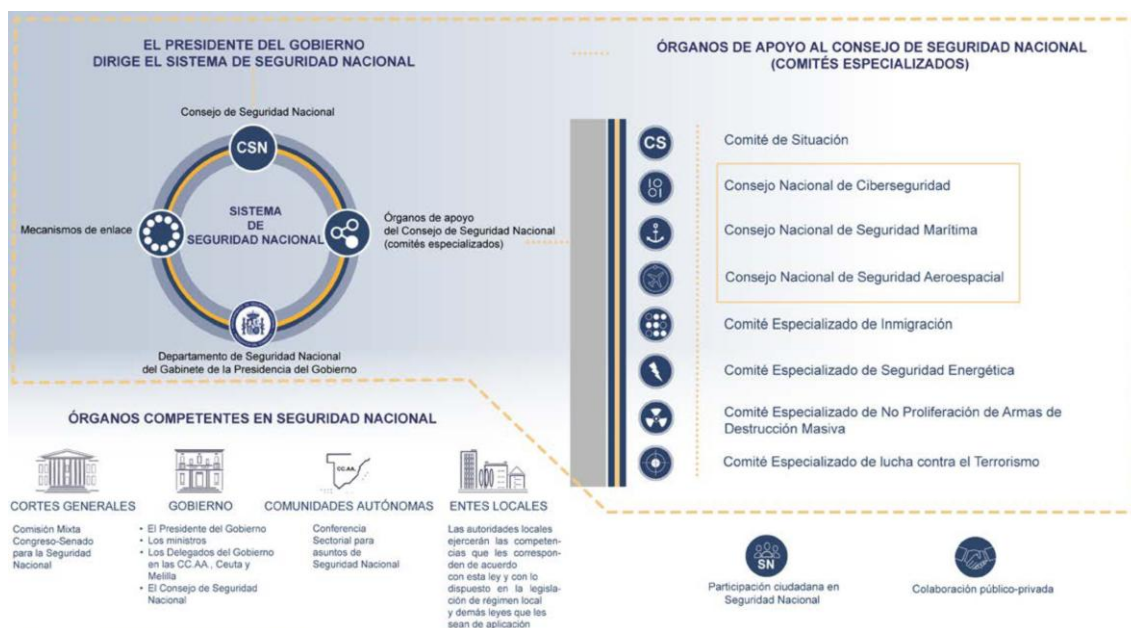
Este capítulo establece los objetivos de la Estrategia: avanzar en materia de gestión de crisis, fortalecer la dimensión de seguridad en sectores estratégicos y desarrollar la prevención, detección y respuesta de España frente a estrategias híbridas. Para ello establece un planteamiento integrado para la Política de Seguridad Nacional con una estructura diseñada por tres ejes estratégicos: proteger, promover y participar. Sobre estos tres ejes se estructuran 33 líneas de acción (L.A.).



## 8.5 EL SISTEMA DE SEGURIDAD NACIONAL Y LA GESTIÓN DE CRISIS (CAP. 5)

El quinto capítulo de la Estrategia presenta un modelo integrado para hacer frente a las situaciones de crisis de forma preventiva, ágil y eficaz en el marco del Sistema de Seguridad Nacional.

El Sistema de Seguridad Nacional es el conjunto de órganos, organismos, recursos y procedimientos que posibilitan la acción del Estado en el ejercicio de las funciones para proteger la libertad y el bienestar de sus ciudadanos, garantizar la defensa de España y sus principios y valores constitucionales, y contribuir junto a socios y aliados a la seguridad internacional.



El avance en integración del Sistema se materializa en seis actuaciones concretas:

- 1) Elaboración del catálogo de recursos de la Seguridad Nacional.
- 2) Preparación de planes de respuesta para determinados escenarios.
- 3) Desarrollo de un sistema de respuesta de alerta temprana y análisis.
- 4) Integración de la información de la Seguridad Nacional a través de soluciones tecnológicas.
- 5) Mejora de las comunicaciones de la Presidencia del Gobierno.
- 6) Integración de las CCAA y las ciudades autónomas de Ceuta y Melilla en el Sistema de Seguridad Nacional.

